

Contexto de la Organización y Alcance del SGSI

ISO/IEC 27001:2022 — Cláusula 4

Código de documento	SGSI-DOC-001	Versión	1.7
Estado	Vigente	Clasificación	Interna
Propietario	Dirección General — Atalaya GP SL	Autor	El consultor (externo)
Fecha de emisión	24/04/2026	Fecha de aprobación	20/08/2026
Aprobado por	Comité de Seguridad Convergente	Registro de aprobación	Acta del Comité de 24/07/2026 y 20/08/2026

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	24/04/2026	El consultor	Emisión inicial para revisión de la Dirección General
1.0	30/04/2026	Dirección General	Aprobación; ratificado por el Comité de Seguridad Convergente el 05/06/2026
1.1	24/07/2026	El consultor	Alta de cuatro interfaces en §7.4 y de un riesgo del propio SGSI en §9.
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Retirada de la narración de versiones del cuerpo; regla de completitud de §7.4 como norma vigente (HD-04).
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Precisión de la regla de completitud de §7.4 (vocabulario cerrado de interfaces).
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	24/07/2026	El consultor	Corrección del número de escenarios sin interfaz declarada (cinco, no cuatro). Ver decisiones.md §19.
1.4	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	24/07/2026	El consultor	Corrección de la composición de la organización (§3, §5, §7.2: nueve personas, siete empleados y dos terceros T2). Ver decisiones.md §20.
1.5	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.5.
1.6	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.6	20/08/2026	Comité de Seguridad	Aprobación de la revisión 1.6.

Versión	Fecha	Autor	Descripción del cambio
		Convergente	
1.7	20/08/2026	El consultor	Alta del diagrama de mapa de interfaces (Figura 1, §7.4).
1.7	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.7.

1. Objeto

Este documento establece el contexto de Atalaya Gestión Patrimonial SL (en adelante, Atalaya o la organización), identifica las partes interesadas pertinentes para su sistema de gestión de seguridad de la información (SGSI) y sus requisitos, y determina y justifica el alcance del SGSI, en cumplimiento de la cláusula 4 de ISO/IEC 27001:2022.

El contexto aquí descrito es la base sobre la que se construyen la política de seguridad de la información, la evaluación de riesgos y la declaración de aplicabilidad. Cualquier modificación posterior del alcance requiere revisión de dichos documentos.

2. Referencias

- ISO/IEC 27001:2022, cláusulas 4.1 a 4.4.
- ISO/IEC 27003:2017, orientación sobre la cláusula 4.
- ESC-001 Ficha de escenario (documento interno del caso).

3. La organización

Atalaya Gestión Patrimonial SL es el family office de la familia Gallagher: una sociedad española cuya estructura la forman nueve personas —siete empleados y dos escolta/conductor externos estables (ESC-001 §4)—, con oficina en Marbella, que gestiona el patrimonio de la familia en España, coordina a los asesores externos en Irlanda y presta soporte operativo a la vida familiar (residencias, viajes, seguridad, administración personal).

A diferencia de una empresa convencional, el activo que Atalaya protege no es propio: es la información patrimonial, personal y de seguridad de una familia. La materialización de un riesgo de información no se traduce en pérdida de negocio, sino en riesgo físico, extorsivo o reputacional directo sobre personas concretas, tres de ellas menores de edad. Esta particularidad condiciona todo el SGSI.

4. Contexto externo (cláusula 4.1)

Cuestiones externas pertinentes para los resultados previstos del SGSI:

Ámbito	Cuestión	Efecto sobre el SGSI
Entorno de amenaza	Criminalidad organizada activa en la Costa del Sol con historial documentado de vigilancia previa a asaltos en grandes residencias. Precedente propio: cuasi-incidente de ingeniería social sobre un miembro de la familia, entre diciembre de 2025 y febrero de 2026, con indicios de vigilancia física de la residencia.	La confidencialidad de rutinas, ubicaciones y dispositivos de seguridad es el requisito dominante, por encima de disponibilidad e integridad.
Exposición pública	Notoriedad histórica del principal y actividad de un miembro de la familia como creador de contenido con audiencia amplia. Huella OSINT familiar elevada y fuera del control de la organización.	El SGSI debe tratar información que se origina y filtra fuera de su perímetro organizativo, a través de interfaces con la familia.

Ámbito	Cuestión	Efecto sobre el SGSI
Jurisdiccional	Patrimonio y sociedades en dos jurisdicciones (España e Irlanda), con flujo continuo de información fiscal y societaria entre asesores de ambos países.	El intercambio seguro con terceros externos es un proceso crítico dentro del alcance.
Regulatorio	RGPD y LOPDGDD (tratamiento de datos personales, incluidos menores); obligaciones mercantiles y fiscales en España e Irlanda; condiciones de confidencialidad de pólizas de seguro personales de la familia, cuya propia existencia es información de máxima sensibilidad.	Requisitos legales y contractuales de confidencialidad que el SGSI debe identificar y cumplir (se desarrollan en el registro de requisitos legales).
Tecnológico	Dependencia total de un proveedor de servicios gestionados (MSP) local que administra red, correo, almacenamiento, videovigilancia y domótica, sin supervisión interna cualificada.	La gestión de proveedores con acceso lógico y físico es un dominio de control prioritario.

5. Contexto interno (cláusula 4.1)

Cuestiones internas pertinentes:

- Gobernanza dual e informal: la autoridad formal reside en el principal, pero la interlocución efectiva y el patrocinio del SGSI corresponden a su cónyuge y a la Dirección General. Las decisiones relevantes se toman con frecuencia por canales informales (mensajería instantánea).
- Cultura de seguridad asimétrica: madurez alta en seguridad física (jefe de seguridad con experiencia, escoltas, residencia protegida) y madurez nula en seguridad de la información. Ambos dominios operan sin conexión: quien protege la finca no tiene visibilidad sobre quién administra sus cámaras.
- El principal minimiza el riesgo de información y rechaza los procedimientos formales; no utiliza medios digitales propios y delega la totalidad de su identidad digital (correo, firmas, credenciales) en su asistente personal. Esta concentración es a la vez una vulnerabilidad y una oportunidad: asegurar a una persona protege al principal entero.
- Círculo histórico: dos personas de máxima confianza del principal disponen de acceso físico permanente (residencia) y de facultades legales amplias (poderes notariales de 2015 no revisados) sin vínculo laboral, contrato de confidencialidad ni presencia en el organigrama.
- Sin inventario de activos, sin clasificación de la información, sin control documental previo. El SGSI parte de cero: no hay sistema anterior que corregir, lo que simplifica el diseño pero exige gradualidad en la implantación.
- Estructura reducida (nueve personas, de las que siete son empleados): imposibilidad estructural de segregación de funciones completa; los controles compensatorios (supervisión, trazabilidad, cuatro ojos en operaciones críticas) deberán suplirla.

6. Partes interesadas y sus requisitos (cláusula 4.2)

Partes interesadas pertinentes al SGSI y requisitos que la organización decide tratar a través del SGSI:

Parte interesada	Necesidades y expectativas	Requisito adoptado por el SGSI
Principal y cónyuge	Protección de la familia y del patrimonio; discreción absoluta; mínima fricción en la vida diaria.	Confidencialidad de la información personal, patrimonial y de seguridad; controles proporcionados que no dependan de la disciplina digital del principal.
Hijos menores	Protección de su seguridad física y de sus	Tratamiento de la exposición digital familiar

Parte interesada	Necesidades y expectativas	Requisito adoptado por el SGSI
	datos personales; no son conscientes del riesgo que genera su exposición.	como interfaz del SGSI; normas de uso acordadas con la familia; protección reforzada de datos de menores (RGPD).
Empleados de Atalaya	Claridad sobre qué se espera de ellos; no ser señalados como sospechosos por defecto ante un incidente.	Políticas y procedimientos claros, formación, y trazabilidad que proteja también al inocente.
Círculo histórico del principal	Mantener la relación de confianza y el acceso del que disfrutaban; rechazo previsible a la formalización.	Regularización del acceso físico, lógico y legal mediante acuerdos proporcionados; es un requisito del SGSI hacia ellos, no de ellos hacia el SGSI, y gestionarlo sin ruptura es condición de viabilidad del proyecto.
Asesores externos (Dublín y España)	Intercambio de información ágil para cumplir plazos fiscales y societarios.	Canal de intercambio seguro que no penalice la operativa; requisitos de confidencialidad recíprocos formalizados.
Banca privada (ES/CH/IE)	Confidencialidad de posiciones; verificación fiable de órdenes; cumplimiento de sus propios estándares de diligencia.	Procedimiento robusto de verificación de órdenes e instrucciones (antifraude); protección de la información financiera.
MSP y proveedores con acceso	Continuidad de la relación comercial; requisitos claros y asumibles.	Cláusulas de seguridad y confidencialidad en contrato; acceso concedido, registrado y revisable; derecho de auditoría.
Aseguradoras (pólizas personales de la familia)	Confidencialidad sobre la existencia y condiciones de las pólizas; deber de sigilo del tomador como condición de cobertura.	Clasificación de máxima sensibilidad para esta información; acceso restringido a dos personas.
Autoridades (AEPD, administraciones fiscales ES/IE)	Cumplimiento normativo; cooperación en caso de requerimiento.	Cumplimiento del RGPD/LOPDGDD y del registro de requisitos legales; capacidad de respuesta a requerimientos sin exponer información no requerida.

7. Alcance del SGSI (cláusula 4.3)

7.1 Declaración de alcance

«El sistema de gestión de seguridad de la información de Atalaya Gestión Patrimonial SL cubre la gestión de la información patrimonial, personal y de seguridad de la familia a la que presta servicio, en los procesos de administración patrimonial, coordinación de asesores externos, soporte a la vida familiar y seguridad, desarrollados desde su oficina de Marbella y la residencia principal de la familia, incluyendo las interfaces con los proveedores y terceros con acceso físico o lógico a dicha información.»

7.2 Inclusiones

- Procesos: administración y reporting patrimonial; coordinación con asesores de España e Irlanda; gestión de órdenes e instrucciones financieras; gestión de viajes y agenda; gestión de residencias y personal; seguridad de personas e instalaciones en su componente de información.
- Ubicaciones: oficina de Atalaya (Marbella) y residencia principal de la familia, incluida la casa de invitados. La residencia entra en alcance porque aloja activos de información esenciales: almacenamiento doméstico con documentación familiar, videovigilancia, domótica, red compartida y el despacho del principal.

- Personas: las nueve personas de la estructura de Atalaya —siete empleados y dos escolta/conductor externos, estos últimos sujetos además a la política de terceros como T2 (SGSI-DOC-006 §2)— y, mediante acuerdos específicos, las personas del círculo histórico con acceso permanente.
- Tecnología: la infraestructura administrada por el MSP (red, correo, almacenamiento, videovigilancia, domótica) en ambas ubicaciones, con independencia de quién la opere.

7.3 Exclusiones y su justificación

Exclusión	Justificación
Gallagher Holdings Ltd, IronWork Athletics Ltd y la participación en la promotora (Irlanda/UK)	Entidades fuera del control de gestión de Atalaya, con administración propia en otra jurisdicción. Excluir las como organizaciones es obligado; no obstante, el flujo de información entre Atalaya y sus gestores permanece dentro del alcance como interfaz crítica (7.4). La exclusión no debilita el SGSI porque lo que Atalaya puede proteger —el canal y la información en su poder— queda cubierto.
Los miembros de la familia como usuarios internos del SGSI	No son empleados ni sujetos a la autoridad de la organización; imponerles políticas internas sería inaplicable y contraproducente. Su exposición digital se trata como cuestión de contexto y como interfaz gestionada mediante acuerdos familiares y acompañamiento, no mediante obligación. Esta decisión es deliberada: un alcance que pretenda gobernar la conducta de la familia fracasa en el primer mes.
Residencia secundaria (Dublín)	Gestionada en remoto por un tercero del círculo histórico, sin presencia de personal de Atalaya ni activos de información relevantes conocidos. Se excluye de esta primera implantación por proporcionalidad; la relación con su gestor sí queda en alcance como tercero con acceso. Revisable en el primer ciclo de mejora.
Prestación operativa de seguridad física (escoltas, vigilancia)	El servicio físico en sí no es un proceso de información. Queda en alcance todo su componente informacional: rutas, rutinas, planos, configuraciones de CCTV y la relación contractual con el proveedor.

7.4 Interfaces y dependencias

Las interfaces son la zona donde este SGSI se juega su eficacia: la información sensible de la familia cruza constantemente los límites de la organización. Se identifican como mínimo:

Interfaz	Información que cruza	Dependencia / riesgo de borde
Atalaya ↔ Familia	Agenda, viajes, rutinas, decisiones patrimoniales; exposición en redes de los hijos.	La organización no tiene autoridad sobre este lado; la interfaz se gestiona por acuerdo y acompañamiento.
Atalaya ↔ Círculo histórico	Acceso físico total a la residencia; facultades legales sobre sociedades; información informal por mensajería.	Acceso real superior al de la plantilla, sin ningún marco formal. Prioridad de regularización.
Atalaya ↔ Asesores Dublín	Información fiscal y societaria completa.	Canal actual: correo sin cifrar y mensajería. Origen del incidente de suplantación plausible.
Atalaya ↔ MSP	Administración de toda la infraestructura, incluida la física conectada (CCTV, domótica).	Un único tercero concentra el poder de administración sobre los dominios físico y digital; nadie lo supervisa.
Atalaya ↔ Banca privada	Órdenes, posiciones, poderes.	Verificación de autenticidad de instrucciones: vector de fraude directo sobre el patrimonio.
Físico ↔ Digital (interna)	CCTV, control de accesos y domótica	La convergencia es constitutiva del

Interfaz	Información que cruza	Dependencia / riesgo de borde
	generan y consumen información; el personal de seguridad física opera a ciegas de su capa lógica.	alcance: los controles físicos y lógicos se planifican como un único sistema.
Atalaya ↔ Servicios contratados en la residencia	Presencia continuada en el interior del perímetro: vigilancia, servicio doméstico, conducción y mantenimiento. Conocimiento directo de rutinas, accesos y calendario de la familia.	Interfaz de mayor frecuencia y menor formalización. El riesgo dominante no es la deslealtad sino la inejecución: controles físicos contratados y operativos cuya ejecución no deja evidencia (RSC-018, RSC-025). La dependencia es de cumplimiento diario, no contractual.
Atalaya ↔ Contratas y trabajos eventuales	Acceso físico temporal a zonas interiores; visión directa de la disposición de la residencia, de los sistemas y de la documentación en papel.	Acceso no planificado ni acreditado: personas desconocidas circulando sin relación nominal previa (RSC-020, RSC-023). La contratación la decide con frecuencia la propiedad sin intervención de Atalaya, lo que sitúa el control aguas abajo de la decisión.
Atalaya ↔ Entorno social de la familia	Acceso físico a la residencia y trato directo con miembros de la familia, sin relación contractual ni verificación de ningún tipo.	Interfaz por la que se produjo el cuasi-incidente fundacional. No admite tratamiento contractual: se gestiona por acuerdo con la familia y por diseño del espacio (SGSI-DOC-006 §8). Su control depende del cumplimiento voluntario y así se declara (RSC-021).
Atalaya ↔ Proveedores de viaje	Itinerarios, fechas, alojamientos y composición del grupo; en destino, servicios locales con acceso a la familia.	La información de viaje se fragmenta entre múltiples proveedores fuera del control de Atalaya y con frecuencia antes de que exista evaluación de destino (RSC-022). El riesgo de borde es la agregación: cada proveedor conoce poco, el conjunto conoce el itinerario completo.

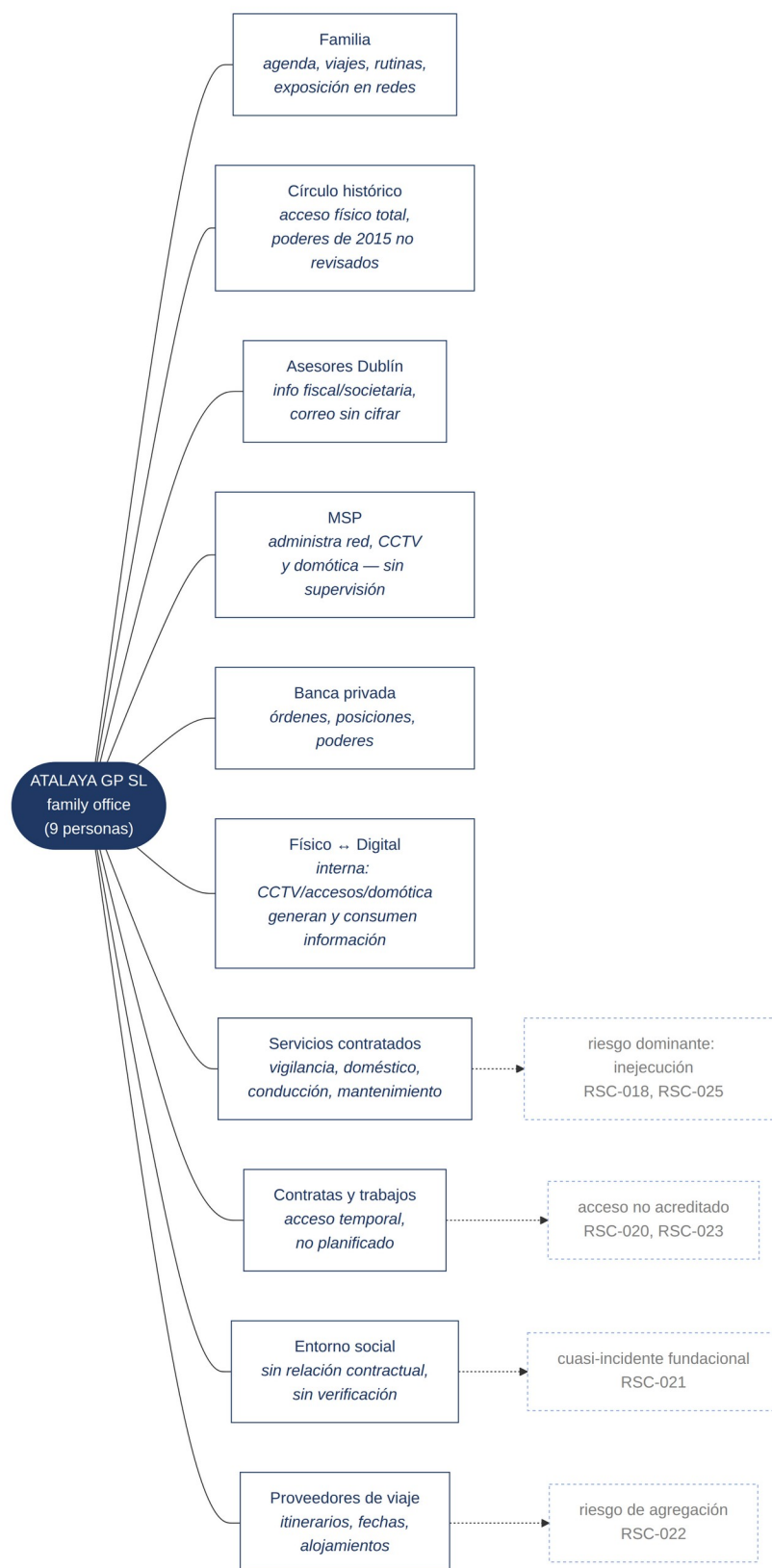


Figura 1. Mapa de interfaces del alcance del SGSI (SGSI-DOC-001 §7.4).

Regla de completitud (SGSI-DOC-004 §5.1): toda interfaz declarada debe tener al menos un escenario de riesgo que la ponga a prueba, y todo escenario debe poder situarse en una interfaz. Cinco escenarios del registro —RSC-018, RSC-020, RSC-021, RSC-022 y RSC-025— no encontraban interfaz donde situarse: la descripción del alcance recogía las interfaces por las que circula información y no aquellas por las que circulan personas. Las cuatro últimas interfaces de la tabla anterior cubren esa laguna. El hallazgo lo produjo el propio sistema y consta registrado como HD-04 (SGSI-DOC-010 §4.1 y SGSI-REG-006). La regla se comprueba sobre la columna «Interfaz» de SGSI-REG-001, que cita estas diez interfaces por

su forma corta y con vocabulario cerrado: Familia, Círculo histórico, Asesores Dublín, MSP, Banca privada, Físico ↔ Digital, Servicios contratados, Contratas y trabajos, Entorno social y Proveedores de viaje. La comprobación se hace en los dos sentidos —ningún escenario cita algo que no esté en esta lista, y ninguna interfaz de esta lista se queda sin escenario que la ponga a prueba— y es la que cierra materialmente HD-04.

8. El sistema de gestión (cláusula 4.4)

Atalaya establece, implementa, mantiene y mejora continuamente un SGSI conforme a ISO/IEC 27001:2022, incluidos los procesos necesarios y sus interacciones. La documentación del sistema se rige por el procedimiento de control documental (SGSI-DOC-002) y este documento se revisa, como mínimo, anualmente y ante cualquier cambio significativo del contexto: variación en la composición o exposición de la familia, cambio de proveedores críticos, incidentes relevantes o modificación de la estructura patrimonial.

Los cambios del SGSI se planifican (cláusula 6.3): toda modificación relevante del sistema —alcance, metodología, estructura de gobierno, alta de una nueva interfaz o de un proveedor crítico— se somete al Comité de Seguridad Convergente con evaluación previa de su efecto sobre los escenarios de riesgo (SGSI-DOC-004, sección 8) y sobre la documentación afectada (SGSI-DOC-002), antes de su entrada en operación.

9. Riesgos y oportunidades para el propio SGSI (cláusula 6.1.1)

Además de los riesgos de seguridad de la información (SGSI-DOC-004 y SGSI-REG-001), la organización identifica lo que puede impedir que el SGSI logre sus resultados previstos. Son riesgos del proyecto y del sistema, no de la información, y se tratan aquí porque su gestión condiciona todo lo demás:

Riesgo / oportunidad	Tratamiento
Rechazo del círculo histórico a la regularización (el riesgo de implantación más alto del proyecto)	El principal antecede personalmente cada acuerdo (SGSI-DOC-006 §4); acuerdos en lenguaje llano y proporcionados; sin plazos agresivos: la relación vale más que el calendario del proyecto.
Incumplimiento ejemplar del propio principal	Tratado en la declaración de compromiso (regla segunda) y en el informe ejecutivo a la propiedad: el día que el principal se salte una regla, el sistema pierde autoridad. La representante de la propiedad tiene el mandato de señalarlo.
Dependencia del consultor externo	Plan de transferencia de conocimiento y cláusula de no dependencia (SGSI-DOC-003 §6.3): a partir del segundo ciclo el sistema debe operar sin consultor, salvo auditoría y revisión anual.
Fatiga normativa de la familia (las reglas se cumplen tres meses y se abandonan)	Diseño de mínima fricción como criterio de la política; las normas que afectan a la familia se acuerdan, no se imponen, vía representante de la propiedad; revisión trimestral de cumplimiento real, no declarado.
Oportunidad: madurez alta preexistente en seguridad física	Se aprovecha como palanca: el jefe de seguridad preside la convergencia y los controles físicos existentes se integran en el SGSI en lugar de duplicarse (SoA: los controles físicos preexistentes figuran como PARCIAL — el medio existe y opera, pero su ejecución no deja evidencia registrada y por tanto no alcanzan cobertura efectiva conforme a SGSI-DOC-004 §6; ver SGSI-REG-006, HD-03).
Patrocinio sostenido en el miedo y no en el criterio de riesgo	El impulso de implantación procede de la reacción al cuasi-incidente, no de una valoración sostenida del riesgo. Un patrocinio de esa naturaleza decae a medida que el suceso se aleja, y con él la exigencia de cumplimiento. Tratamiento: la declaración de una página la firma el principal y no el cónyuge, de modo que el compromiso formal no dependa de quien lo impulsó por temor; los indicadores del ciclo (SGSI-DOC-005) miden ejecución sostenida y no implantación puntual; y la revisión por la dirección incorpora expresamente la evolución del cumplimiento en el tiempo como punto de orden.

Anexo A. Trazabilidad con ISO/IEC 27001:2022

Sección de este documento	Cláusula ISO/IEC 27001:2022
4 y 5 — Contexto externo e interno	4.1 Comprensión de la organización y su contexto
6 — Partes interesadas y requisitos	4.2 Comprensión de las necesidades y expectativas de las partes interesadas
7 — Alcance, exclusiones e interfaces	4.3 Determinación del alcance del SGSI
8 — El sistema de gestión; planificación de cambios	4.4; 6.3
9 — Riesgos y oportunidades del SGSI	6.1.1